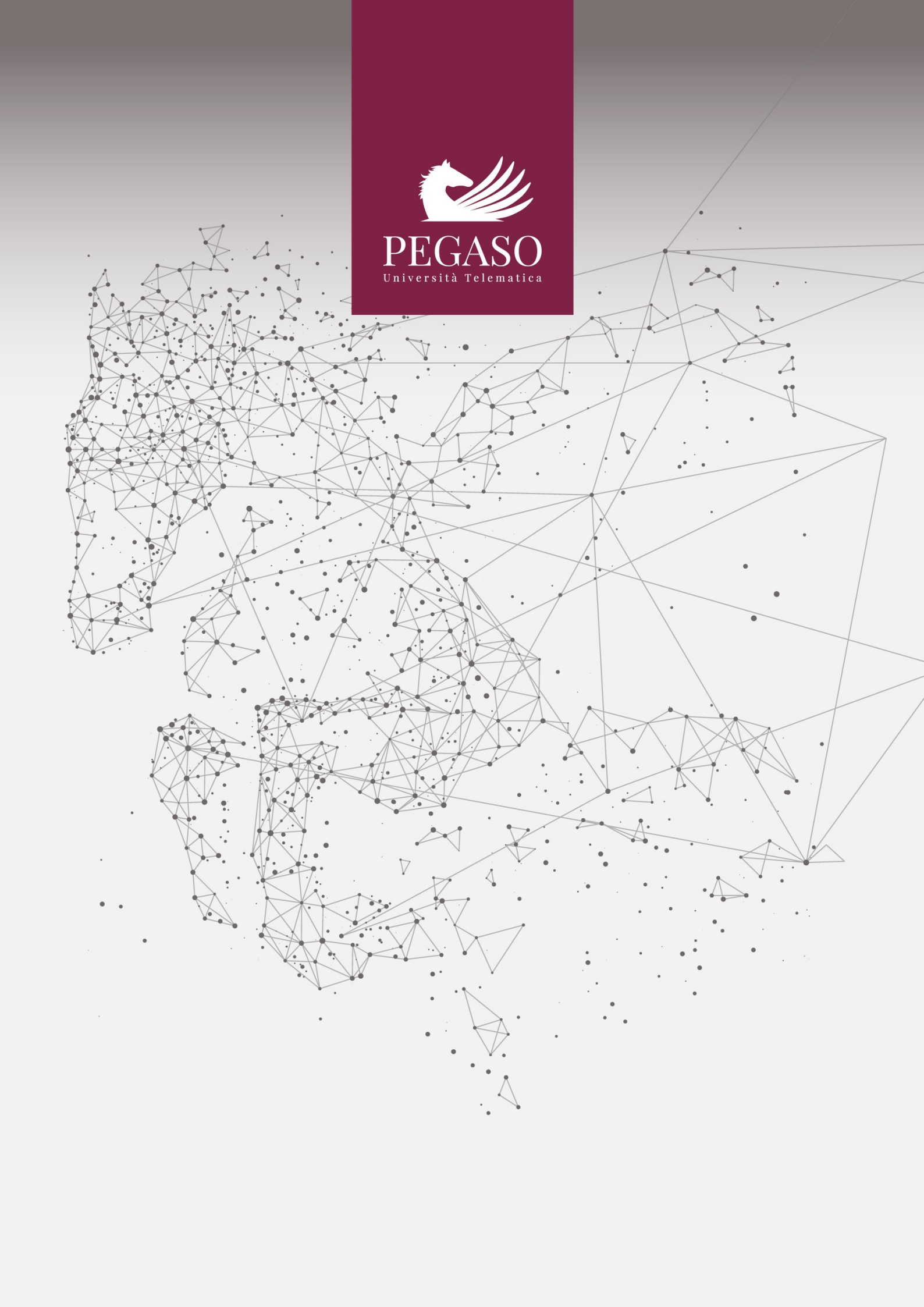

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 LA RETE TOR 3

2 TOR: SERVIZI NASCOSTI 7

3 DEEP WEB 9

SITOGRAFIA 13

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 La rete Tor

L'acronimo ***Tor*** sta per *The Onion Router;*

Tor è una rete orientata all'anonimato sostanzialmente basata sul protocollo MIX ma con degli accorgimenti superiori:

- garantisce la Perfect Forward Secrecy per le chiavi
- introduce le cosiddette *guardie* per aumentare l'anonimato del mittente
- introduce le sessioni per la comunicazione a lungo termine
- tiene conto della disponibilità di banda durante la selezione dei proxy (in Tor i proxy si chiamano relay)
- introduce i servizi nascosti ovvero dei server accessibili solo attraverso la rete Tor

Tor rappresenta sicuramente il servizio orientato all'anonimato più noto e usato su Internet:

- pubblicato nel 2002, è continuamente sviluppato e migliorato
- i Tor relay sono gestiti da volontari (forse alcuni gestiti da agenzie di intelligence)
- ogni giorno si registrano in media tra i 500K-1M di utenti.

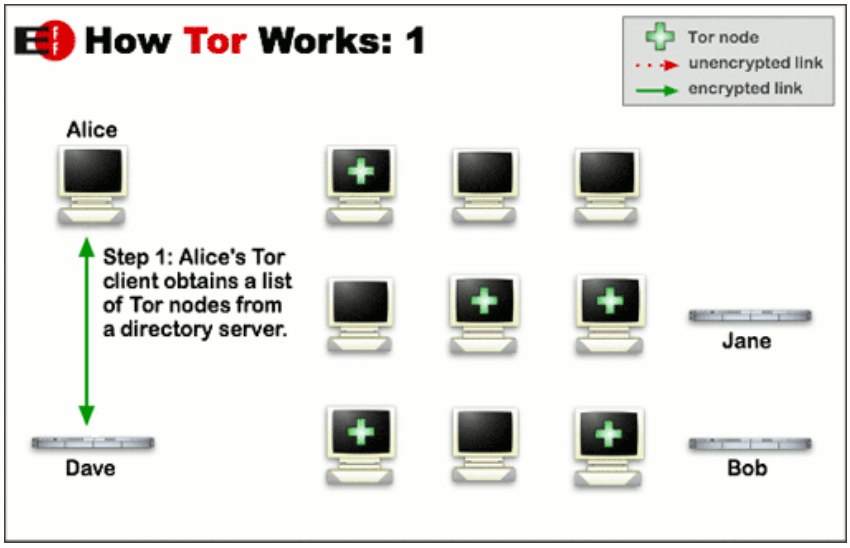
Per trovare i Tor relay esistono dei *directory server* che possiedono il *Tor Consensus File*, tale file contiene la lista di tutti i relay con le loro caratteristiche: indirizzo IP, stato, larghezza di banda, ecc.

Non tutti i relay sono uguali, i relay di entrata o guardia e quelli di uscita sono etichettati differentemente; la selezione dei relay non avviene casualmente ma sulla base della capacità di banda. Vediamo adesso il funzionamento.

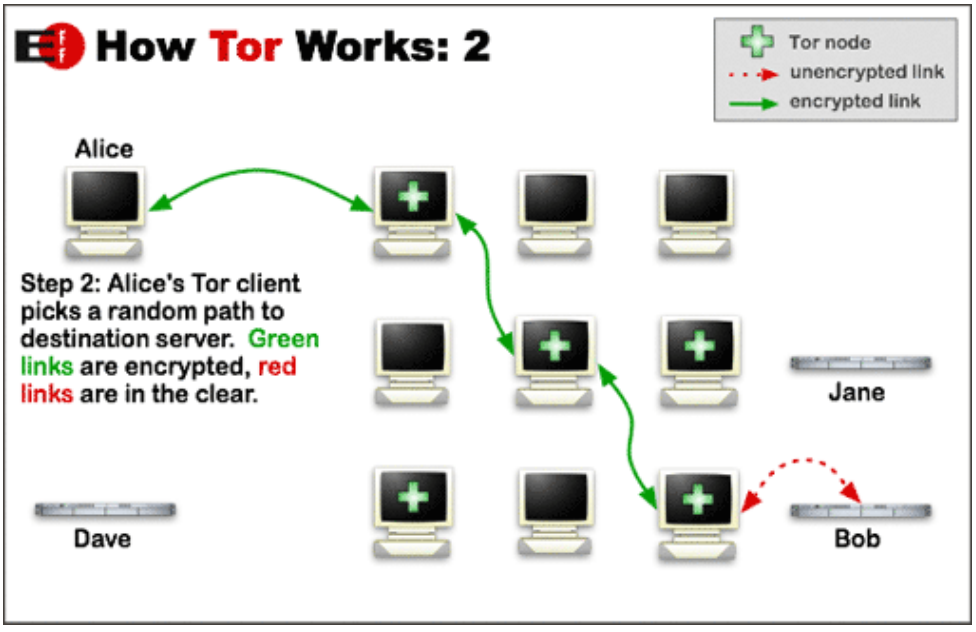
Passo1: il client tramite il directory server ottiene la lista dei Tor relay (vedi figura)

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



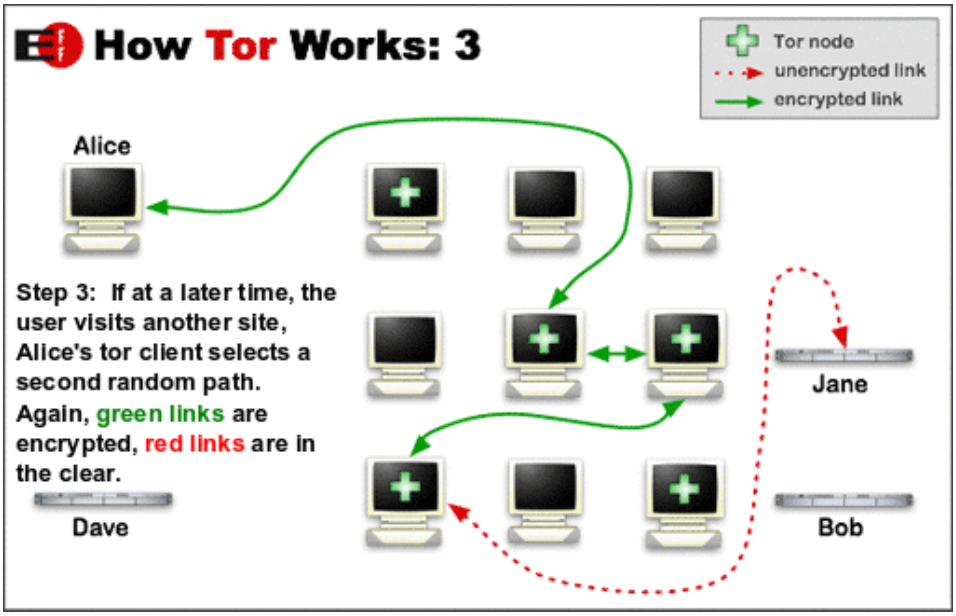
Passo2: il client Tor sceglie un percorso random verso il server di destinazione, come si vede in figura, i link fra il client e il Tor relay di entrata e fra i Tor relay interni sono cifrati mentre il link fra il Tor relay di uscita e il server di destinazione è in chiaro



Passo3: per un certo periodo di tempo (circa 10 min) il percorso viene mantenuto, se l'utente visita successivamente un altro sito il client Tor ne seleziona un altro.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Nel caso del *Predecessor attack,* se supponiamo che:

- il numero dei relay sia *N*
- *M* sia il numero di quelli controllati da un attaccante

l'obiettivo dell'attaccante che esegue questo tipo di attacco è quello di riuscire a controllare il primo e l'ultimo relay:

- M/N è la probabilità che un relay corrotto sia il primo
- (M-1)/(N-1) è la probabilità che un relay corrotto sia l'ultimo
- la probabilità è quindi dell'ordine di $(M/N)^2$ per un singolo circuito

Siccome il client periodicamente costruisce nuovi circuiti, la probabilità per un relay corrotto di trovarsi in posizione utile aumenta nel tempo.

I **relay di guardia** servono proprio ad impedire ad eventuali attaccanti di diventare il primo relay del circuito. Tor seleziona 3 relay guardia e li usa per un certo periodo di tempo (3 mesi);

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

dopo tale periodo ne seleziona altri 3. Solo relay con specifiche caratteristiche possono diventare relay guardia; generalmente essi presentano:

- lunghi e continuati periodi di funzionamento
- elevate capacità di banda
- adeguata manutenzione

Nel caso in cui anche il relay guardia sia corrotto, allora si ha una probabilità dell'ordine di M/N di incorrere in una completa compromissione del circuito.

Nelle tradizionali reti Mix, il traffico è cifrato usando coppie di chiavi pub/priv, ma nel caso in cui la chiave privata venga rubata accade che:

- tutto il traffico futuro può essere decifrato e osservato
- inoltre, se il traffico passato è stato registrato anche questo può venire decifrato

Tor invece implementa quella che si chiama la *Perfect Forward Secrecy (PFS)* ovvero:

- il client negozia una nuova coppia di chiavi pub/priv con ognuno dei relay
- le coppie originali di chiavi sono usate solo per la firma digitale ovvero per verificare l'autenticità dei messaggi. Il traffico è cifrato con chiavi temporanee.

Un attaccante che entrasse in possesso di una chiave privata potrà soltanto intercettare il traffico futuro ma non quello passato cifrato con chiavi ormai scadute e non memorizzate da nessuna parte.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

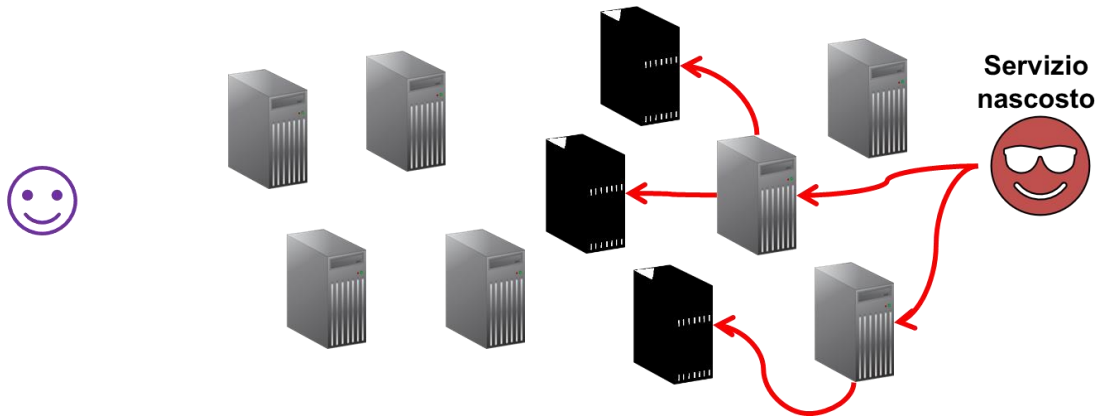
2 Tor: servizi nascosti

Il sistema Tor riesce a nascondere piuttosto bene la sorgente del traffico ma spesso la destinazione è un sito web esposto; nonostante ciò, Tor consente di connettersi a dei servizi nascosti di cui non si conosce l'indirizzo IP. Tor infatti supporta i cosiddetti «hidden services» che realizzano una connessione senza rivelare l'indirizzo IP

- *Silk Road 2.0*
- *The pirate bay*
- *Tor mail*

Vediamo come si accede ai servizi nascosti.

Passo1: il servizio nascosto espone il proprio servizio su dei Tor relay che fungono da punti di introduzione (relay in nero in figura)

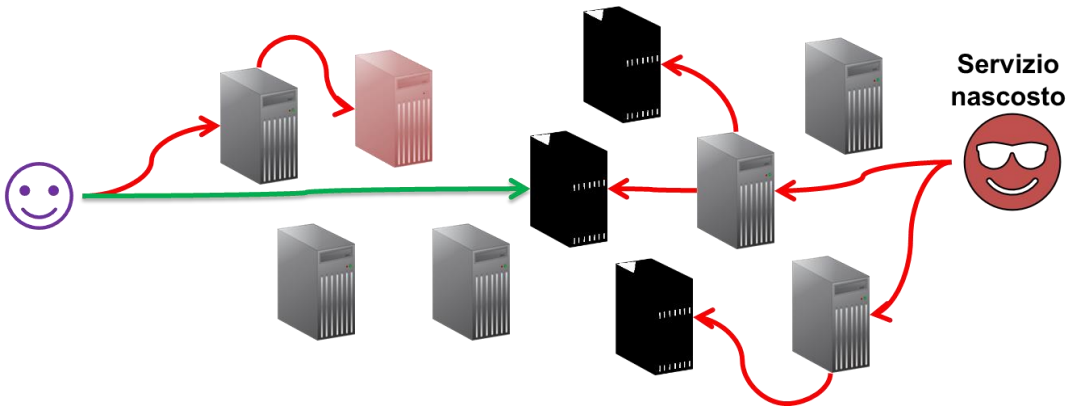


Passo1bis: i punti di introduzione si presentano agli utenti Tor come *onion url* (https://g3nndkjdf8jkrbeef4o.onion) e sono degli hash con estensione .*onion*.

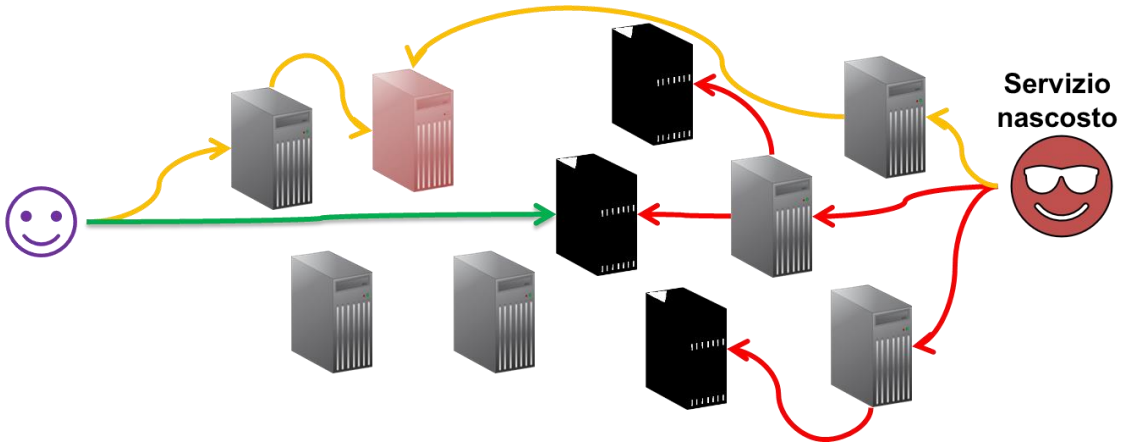
PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Passo2: l'utente Tor seleziona un relay di rendezvous (*appuntamento*), come evidenziato in figura con il server in rosa, e lo comunica connettendosi ad un *onion url* di un punto di introduzione (link in verde in figura).



Passo3: il servizio nascosto si collega al relay di rendezvous e tramite quello si stabilisce il circuito di comunicazione (evidenziato in giallo)



PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Deep Web

Il web normalmente conosciuto è solo una piccola parte del web esistente, esiste in realtà tutta un'altra parte di web che va sotto il nome di «web invisibile» oppure di *deep web* o *deep internet* che è costituita da tutta quella informazione che non è indicizzata dai consueti motori di ricerca quali Google, Bing, Yahoo, ecc.

I motori di ricerca usano uno spider per raccogliere più pagine web possibili e passarle ad un indexer (*web crawling*) che appunto indicizza pagine e contenuti; ogni indexer ha un suo algoritmo di ranking per proporre le risposte sulla base delle keyword di richiesta degli utenti.

Una pagina per essere trovata deve essere statica e collegata ad altre pagine; tutte le pagine e i contenuti indicizzati rappresentano il web visibile o surface web, invece tutte le pagine e i contenuti non indicizzati rappresentano appunto il web invisibile o deep web: la maggior parte delle pagine non viene indicizzata. Si stima infatti che il 75% dell'intera Internet sia costituito dal web invisibile.

I contenuti che si possono trovare nel web invisibile sono di varia natura:

- Pagine web senza link verso di esse (pagine disconnesse)
- Pagine web protette da password
- Pagine web generate da DB o dinamicamente
- Contenuti in tempo-reale
- Pagine web che richiedono una registrazione di accesso
- Pagine web non HTML o con codifiche che uno spider non riesce a interpretare

In realtà questo è ciò che viene più specificatamente indicato come **Deep Web Layer1**.

Il **Deep Web Layer2** è invece quello più profondo ed accessibile soltanto attraverso software orientati all'anonimato come Tor o reti anonime e darknet (I2P). Esso rappresenta una sorta di paradiso protetto per contenuti che sarebbero proibiti sul surface web. Esempi di contenuti

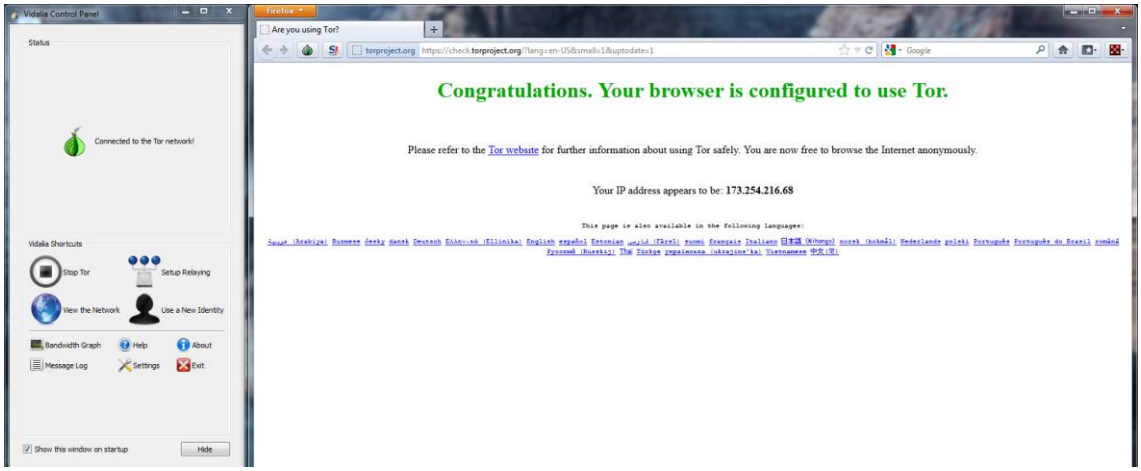
PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

sono le chat anonime, pagine per il commercio di droga, armi, software illegali, multimedia pirata, foto compromettenti e oscene……

Per accedere nel Deep Web si usano generalmente i "servizi nascosti" esposti tramite i domini con suffisso *.onion* e accessibili attraverso la rete Tor. Gli indirizzi seguiti dal suffisso *.onion* sono costituiti da hash di 16 caratteri alfa-numerici. Il termine *onion* si riferisce al tipo di protocollo di routing (*onion routing*) utilizzato dalla rete Tor per garantire l'anonimato; tali sistemi permettono di rendere difficile da tracciare, per un soggetto terzo o anche per un nodo intermedio della rete, sia colui che fornisce i contenuti sia colui che li richiede.

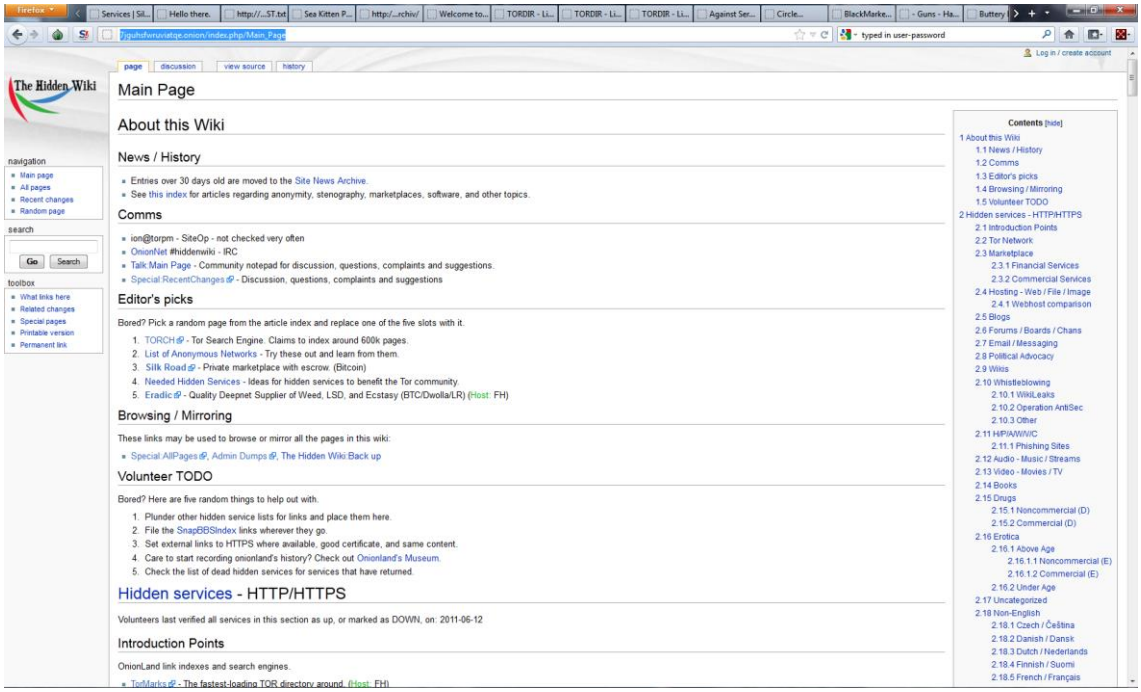
Per accedere il primo passo è installare e lanciare il Tor Bundle per realizzare un nuovo browser anonimo basato su Firefox (in figura viene dato un esempio).



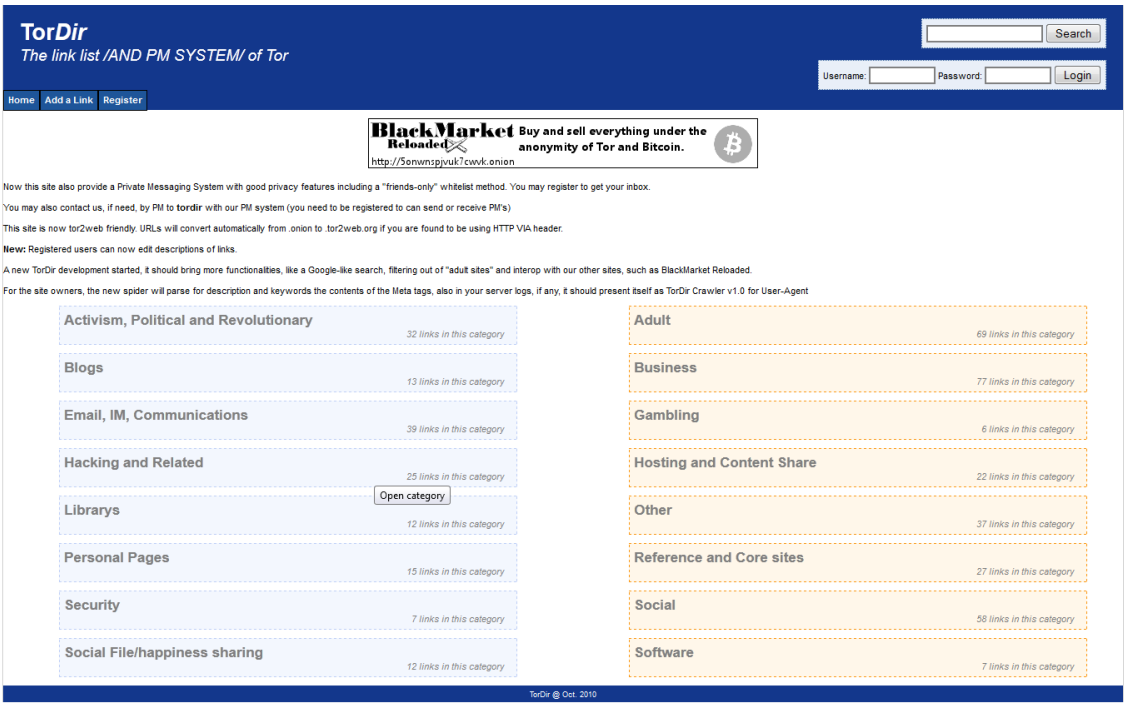
Vediamo adesso, solo per avere un'idea generale, alcuni dei contenuti che si possono trovare. Tanto per esempio, questo è *Hidden Wiki* che molti considerano la home page del Deep Web dove si possono trovare differenti tipi di siti e reti

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



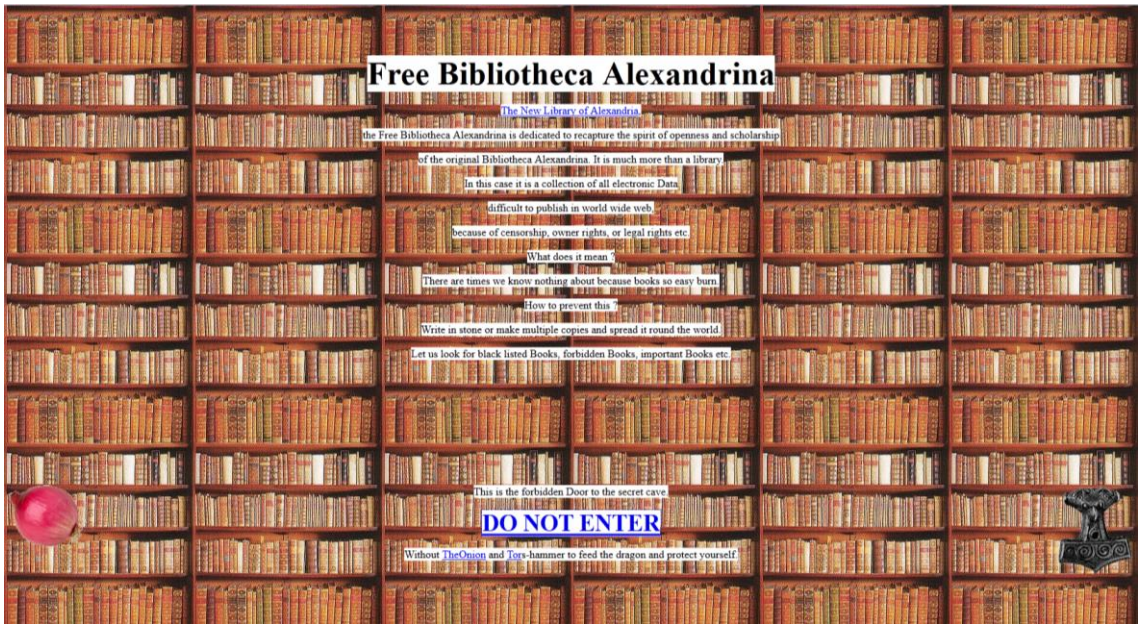
Un'altra delle pagine principali è *TorDir,* un sito che usa uno speciale crawler per il Deep Web che organizza i servizi in categorie



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Infine, un ultimo esempio per capire che una grande parte del Deep Web non è malevola.

Questo è il caso di un enorme archivio con libri proibiti o che sono stati bruciati nel passato.



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Sitografia

- The Tor Project: https://www.torproject.org
- Onion Routing: https://www.onion-router.net/

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).